

RAMAI

Security, GDPR & AI Act v1.0

AI Business Operating Assistant for PMI - Documento 08

Scopo. Stabilire la baseline di sicurezza, privacy, conformità e governance AI necessaria per un SaaS europeo che accede a email e dati CRM di PMI.

1. Security posture

RAMAI tratta email, CRM, appuntamenti e dati commerciali: la sicurezza è una condizione di prodotto e di fiducia, non un requisito da aggiungere dopo la beta.

2. Principi

- Least privilege e deny by default.
- Tenant isolation verificata automaticamente.
- Encryption in transit e at rest; secrets separati dai dati applicativi.
- No production data nei log applicativi o nei test.
- Human approval per azioni esterne ad impatto nell'MVP.
- Data minimization, purpose limitation e retention configurabile.

3. Threat model sintetico

Rischio	Contromisure core
Cross-tenant data leakage	TenantContext server-side, query filters, authz, security tests IDOR.
OAuth token theft	vault, encryption, short-lived access tokens, no frontend exposure.
Prompt injection da email/documenti	untrusted content isolation, tool allowlist, evidence validation.
LLM data exfiltration	provider settings/DPA, minimize context, no secrets, tenant boundary before retrieval.
Account takeover	secure auth, session controls, MFA roadmap, rate limit.
Malicious automation	approval gates, action policies, audit log.
Webhook spoofing	signature validation, replay protection.

4. Identity e authorization

- Identity provider conforme OIDC/OAuth 2.1; password hashing moderno se auth locale.
- Ruoli iniziali: Owner, Admin, Member; futuro Viewer/Auditor.
- Autorizzazione a livello application service, non solo UI.
- Owner richiesto per billing, delete tenant, connector ad alto privilegio.
- Session invalidation su password reset, compromissione o offboarding.

5. Data classification

Classe	Esempi	Controlli
C0 Public	sito, pricing	standard.
C1 Internal	configurazioni non sensibili	auth + logging.
C2 Confidential	CRM, email metadata, insight	encryption + tenant isolation + audit.

Classe	Esempi	Controlli
C3 Restricted	email body, OAuth tokens, eventuali dati personali sensibili	minimization, encryption forte; token in vault; access strict.

6. GDPR - ruoli e basi

Per il SaaS B2B, tipicamente il cliente agisce come titolare del trattamento per i dati dei propri contatti e RAMAI come responsabile per i trattamenti effettuati per conto del cliente. La qualifica esatta e le basi giuridiche devono essere validate con consulenza legale prima del go-live.

- DPA disponibile self-service.
- Elenco sub-processors e localizzazione dati pubblicati.
- Record delle attività di trattamento e data flow map.
- DSRA process: accesso, rettifica, cancellazione, portabilità ove applicabile.
- DPIA da valutare in base alle funzioni finali, soprattutto se profiling/scoring diventa significativo.

7. Privacy by design

Area	Decisione MVP
Import email	periodo limitato; utente informato prima di OAuth.
Allegati	non importati di default.
Training provider	scegliere configurazione/API che non usi i dati cliente per training senza consenso.
Retention	policy documentata; delete tenant avvia purge asincrono verificabile.
Telemetry	pseudonimizzata; no body email nei log.
Analytics product	eventi di uso senza contenuto business.

8. EU AI Act - impostazione prodotto

RAMAI deve mantenere un inventario delle funzioni AI e classificare i casi d'uso. L'MVP è progettato come assistente decisionale/operativo con trasparenza e supervisione umana, evitando usi vietati o decisioni ad alto rischio. Le qualificazioni legali vanno riviste a ogni espansione di funzionalità.

- L'utente deve sapere quando un output è generato o inferito dall'AI.
- Conservare informazioni su modello/prompt/versione per audit tecnico.
- Distinguere raccomandazione da fatto osservato.
- Human oversight per invio/modifica esterna durante MVP.
- Documentare limitazioni, errori noti e modalità di feedback.

9. AI-specific security

Controllo	Implementazione
Prompt injection	content isolation + no execution of source instructions.
Tool abuse	allowlist tools, typed parameters, authz per tool.
Data poisoning	source/provenance, correction workflow, confidence.
Hallucination	evidence requirement, structured output, eval.
Model outage	fail closed per azioni; graceful degradation per read-only.
Sensitive context	redaction/minimization prima del provider quando possibile.

10. Secure SDLC

- Branch protection e review obbligatoria per auth, security e schema migrations.
- SAST, dependency scanning, secret scanning e container scanning in CI.
- DAST/API security test in staging.
- Penetration test prima del public launch e dopo modifiche major.
- SBOM e inventario dipendenze.

11. Audit logging

Evento	Dati minimi
Login/security	utente, tenant, esito, timestamp, IP sintetico/necessario
Connector	connect/reconnect/disconnect, scope, provider
AI action	feature, model, prompt version, source ids, esito
Draft/action	chi ha generato/modificato/approvato
Admin	ruoli, billing, privacy settings, delete requests

12. Incident response

- On-call/owner definito anche in fase founder-led.
- Playbook per credential leak, tenant leakage, provider compromise, data loss.
- Capability di revoca globale connector/sessioni.
- Forensic log retention protetta e accesso ristretto.
- Processo per valutazione e notifica data breach secondo GDPR, con supporto legale.

13. Backup e resilience

Elemento	Baseline
PostgreSQL	backup automatici + PITR
RPO	<= 24h iniziale; target migliore per produzione
RTO	<= 4h iniziale
Object storage	versioning se usato
Secrets	backup/rotation secondo provider
Restore test	trimestrale nella fase iniziale

14. Go-live security gate

- Tenant isolation test suite verde.
- No critical/high vulnerabilità note non accettate formalmente.
- DPA/privacy policy/subprocessor page pronte.
- Delete/export data flow testato end-to-end.
- Pen test completato o pianificato prima di apertura pubblica ampia.
- AI transparency copy presente nelle UX rilevanti.
- Incident owner e procedure definite.

Stato documento: baseline v1.0. Le modifiche sostanziali devono essere versionate e tracciate.

Documento precedente: 07_Connectors_Architecture_v1.0

Documento successivo previsto: 09_Pricing_Business_Model_v1.0

